



HORIZON CAMPUS

Faculty of Information Technology *TNT*

12/13 IT41012 - Research Methodology

Assignment 1: Research Proposal

A quantized and resource-efficient Python framework for edge-based ML analysis to minimize false positives in local Static Application Security Testing scans.

Submitted by

M.Thilini Samanthika

Student ID: ITBIN-2313-0061

Module Code: ***TNT 12/13 IT41012***

Module Leader: Mr. Thilina Samarasinghe

Academic Year 2026 — Third Year, Second Semester

Submission Date: [26 MAY 2026]

Contents

1. Selected Area	3
2. Introduction.....	3
3. Research Problem	3
4. Research Questions.....	4
5. Aim	4
6. Objectives	4
7. References.....	5

1. Selected Area

DevSecOps , Edge Intelligence , Framework Automation , and Software Security Engineering

2. Introduction

SAST local tools are available in developer environments (IDEs) and they can use them to find structural application security vulnerabilities like within the source files, early before code is committed via a "shift left" security approach with modern software engineering models so as not block the build pipeline on these issues. In contrast, a number of works that utilise ML and DL models (instead of regex), are more focused on understanding the context of the code tokens [1]

In particular, the hybrid CNN-LSTM is memory and floating point intensive and computationally expensive [4]. Thus, it can only mostly be used on super-highperformance server side GPUs or cloud computing giant server clusters [13] [16]. Moreover, when executed natively on the developers' desktop [7] [20], this imposes significant performance penalties that hinder subsequent modeling. In this paper, we propose a new lightweight Python implementation of Model Quantization to drive machine learning code analysis, enabling it to run in local environments on commodity hardware with fast turnaround times and code privacy.

3. Research Problem

While this suite of machine learning integrations has been proven effective for contextual vulnerability detection, the developer-facing local workflow still suffers from two critical open bottlenecks in its application.

Off-the-shelf open-source SAST engines generate too many false positives due to their non-contextual methodology, leaving the software engineering industry suffering from alert fatigue while burning developer time and money on manual code audits to remove false positive alarms 2. However recent contextualized deep neural network SAST models show that they could play a part in automating the removal of warning, these security models are limited to unrestricted deployment on the cloud.[6][13]

But having such an expensive model on a local workstation may cause fast compilation overhead, CPU throttling and RAM exhaustion 7. However, although efforts have been made towards edge model compression for computer vision [15] and Internet of Things networks [16,18,19], we are not aware of any research that has examined a quantized lightweight Python framework that can execute abstract code syntax models locally at the edge without compromising local workstation speed or performance. This work addresses one of the key challenges facing the localized static analysis space: bridging the hardwareefficiency gap.

4. Research Questions

- RQ1: What are the quantitative limits associated with using non-optimized deep learningbased models for filtering out vulnerabilities on local developer computers that have limited resources in terms of CPU throttling, memory consumption, and latency?
- RQ2: How can an edge-optimized Python framework be created that minimizes memory and execution overhead while supporting local SAST false-positive minimization and PTQ inference?

5. Aim

The purpose of this research will be to design, deploy, and evaluate a quantized yet efficient algorithm that is entirely written in Python and can perform machine learning at the edge in order to filter out false positives of local static application security testing without affecting the performance of the host workstation.

6. Objectives

- To study microarchitecture (that is, what are the false positives in localized opensource static security scanners, and how they control the architectural styles and limitations on code structure [2]).
- To measure the computational overhead (in terms of power depletion, RAM spikes and processing slowing down) when accessing limited local endpoints to execute common deep learning code-representation models [7].
- To Onto security analysis graphs, post-training quantization using ONNX Runtime and TensorFlow Lite has also been examined for smaller structure models (core magnitude). [15] [16].
- To develop a lightweight edge framework software for Python which smoothly executes both spatial localization of warning noise as well as real-time code vulnerability analysis on commodity class edge hardware [18] [19]

7. References

- [1] London, UK: Packt Publishing, 2019; T. H. C. Hsu, Practical Security Automation and Testing: Tools and Techniques for Automated Security Scanning, 1st ed. [Online]. Accessible:
https://books.google.lk/books?hl=en&lr=&id=z4KGDwAAQBAJ&oi=fnd&pg=PP1&dq=%5B1%5D+T.+H.+C.+Hsu,+Practical+Security+Automation+and+Testing:+Tools+and+Techniques+for+Automated+Security+Scanning,+1st+ed.+London,+UK:+Packt+Publishing,+2019.+%5BOnline%5D.+Available:&ots=otUNSZwgNW&sig=Jg3XyldGOTB3R6HB0Czc7irQrFQ&redir_esc=y#v=onepage&q&f=false
- [2] "Enhancing web application penetration testing with a static application security testing (SAST) tool," M. Y. Darus, M. F. B. Bolhan, and A. Kurniawan, Proceedings of the IEEE International Conference, 2023. [Online]. Accessible:
<https://ieeexplore.ieee.org/abstract/document/10468317>
- [3] "ZenGuard: A machine learning based zero trust framework for context aware threat mitigation using SIEM SOAR and UEBA," Scientific Reports, vol. 15, no. 1, 2025. [Online] A. Hassan, A. Rauf, N. Shafqat, R. Latif, and H. Khan. Accessible:
<https://www.nature.com/articles/s41598-024-84661-0.pdf>
- [4] "DevSecOps-Driven Security Integration in the Software Development Lifecycle Using CI/CD Pipelines," H. P. Cyril and S. Kumara, Proceedings of the IEEE 5th International Conference on AI, 2026. [Online]. Accessible
<https://ieeexplore.ieee.org/abstract/document/11395737>
- [5] Y. Anandhakumar, "Hybrid Detection of Cross-Site Scripting (XSS) Vulnerabilities in Web Applications," doctoral dissertation, Cardiff University, Cardiff, UK, 2025. [Online]. Accessible:
<https://orca.cardiff.ac.uk/id/eprint/179739/1/2025kayanhphd.pdf>
- [6] "Comparative analysis of AI-driven security approaches in DevSecOps: Challenges, solutions, and future directions," F. Binbeshr and M. Imam, ProQuest Dissertations and Theses, 2025. [Online]. Accessible:
<https://dl.acm.org/doi/epdf/10.1145/3727967.3756841>
- [7] M. A. Quraishi, "SECURING LOW-POWER EDGE AI: A VULNERABILITY ANALYSIS AND CYBERSECURITY FRAMEWORK FOR RESOURCE-CONSTRAINED DEVICES," ResearchGate

Technical Reports, 2024. [Online]. Accessible: [https://www.researchgate.net/profile/Muhammad-AmirQuraishi/publication/397839095_SECURING_LOW-POWER_EDGE_AI_A_VULNERABILITY_ANALYSIS_AND_CYBERSECURITY_FRAMEWORK_FOR_RESOURCE-CONSTRAINED-DEVICES/links/69207f1cabe27c41e514230c/SECURINGLOW-POWER-EDGE-AI-A-VULNERABILITY-ANALYSIS-AND-CYBERSECURITY-FRAMEWORKFOR-RESOURCE-CONSTRAINED-DEVICES.pdf](https://www.researchgate.net/profile/Muhammad-AmirQuraishi/publication/397839095_SECURING_LOW-POWER_EDGE_AI_A_VULNERABILITY_ANALYSIS_AND_CYBERSECURITY_FRAMEWORK_FOR_RESOURCE-CONSTRAINED_DEVICES/links/69207f1cabe27c41e514230c/SECURINGLOW-POWER-EDGE-AI-A-VULNERABILITY-ANALYSIS-AND-CYBERSECURITY-FRAMEWORKFOR-RESOURCE-CONSTRAINED-DEVICES.pdf)

[8] "Intrusion detection with HACDT-Net and TRBM-Net using a hybrid deep learning framework with enhanced sampling techniques," Scientific Reports, vol. 16, 2026, N. P. Priya and G. Mohanbabu. [Online]. Accessible:

https://www.nature.com/articles/s41598026-39724-9_reference.pdf

[9] "ScanDroidX: A Mobile-Native Security Tool with MITRE ATT&CK Mobile Integration for Pre-Deployment Web Application Assessment," ProQuest Global, 2026, A. Anthony, A. Daniel, and R. Tiwari. [Online]. Accessible:

<http://ieeexplore.ieee.org/abstract/document/11437459>

[10] Dikshant and G. Verma, "Noise or Alert? "Active Behavioral Analysis for Cloud Security: Reducing False Positives," ProQuest Public Health, 2026. [Online]. Accessible:

<https://dl.acm.org/doi/epdf/10.1145/3797823.3797850>

[11] "Personal Data Privacy Auditor—A Hybrid Framework for Local PII Detection and Browser Tracker Analysis," V. M. Sujith, A. P. Gopu, S. Abinaya, and B. Gokul, ProQuest Core, 2026. [Online]. Accessible:

<https://ieeexplore.ieee.org/abstract/document/11484150>

[12] G. Bajantri, "Enhancing Software Security with CNN-LSTM Hybrid Model: Vulnerability Detection," ProQuest Platform, 2025. [Online]. Accessible:

<https://www.proquest.com/openview/fe835e6139da56de725bf5e75af1f3d2/1>

[13] "Automated software vulnerability scanning frameworks for resource-constrained edge computing environments," L. Wang, M. Zhang, and X. Liu, Preprints, pp. 1-18, 2024 [Online]. Accessible:

https://www.preprints.org/frontend/manuscript/0eae876ebdd1f2635b57bd37b364d209/download_pub

[14] "Quantized Object Detection for Real-Time Inference on Low-Power Computing Platforms," A. Di Sorbo et al., HAL Open Science, Research Report vol. 3, pp. 12-28, 2024 [Online]. Accessible :

https://hal.science/hal-05102885v1/file/Paper_3Quantized_Object_Detection_for_Real_Time_Inference.pdf

[15] "Efficient edge intelligence: Deep model compression and post-training quantization algorithms," arXiv preprint arXiv:2506.09300, 2025, J. Kim, N. Park, and S. Choi. [Online]. Accessible: <https://arxiv.org/pdf/2506.09300>

[16] M. A. Quraishi, "A localized deployment strategy for quantized structural models within Git hooks," Google Drive Repository (Technical Documentation), pp. 1–15, 2025. [Online]. Accessible:

<https://drive.google.com/file/d/1lzn2FxxFKHbvPi5uRFQOwXPdMqnhF2Ug/view>

[17] R. Purba and K. S. Wong, "Mitigating alert noise in static application security testing using resource-efficient inference at the edge," ACM Digital Library, vol. 57, no. 2, pp. 114135, 2025 [Online]. Accessible:

<https://dl.acm.org/doi/pdf/10.1145/3793197>

[18] S. Bajpai, "Anomaly and Behavioral Analysis for Building Effective Threat Models in Cybersecurity," International Journal of Engineering Research & Technology (IJERT), vol. Nov. Dec. 2023, vol.14 no.12 pp 1–8 doi: 10.17577/IJERTV14IS120272. [Online]. Available:

<https://www.ijert.org/research/building-effective-threat-models-in-cybersecurity-by-anomaly-and-behavioral-analysis-IJERTV14IS120272.pdf>

[19] "Benchmarking hardware constraints, CPU throttling, and floating-point precision reduction during local code security analysis," arXiv preprint arXiv:2111.06705, 2021, T. Dunlap and S. Thorn. [Online]. Accessible:

<https://arxiv.org/pdf/2111.06705>

[20] G. Malik and S. Kumara, "Automating software vulnerability screening in DevSecOps pipelines with localized static analyzers," ACM SIGMETRICS Performance Evaluation Review, vol. 46, pp. 88-97, 2018. [Online]. Accessible:

<https://dl.acm.org/doi/pdf/10.1145/3240765.3243479>

[21] "Quantization optimization strategies for deep neural network inference calibration," arXiv preprint arXiv:2408.00197, 2024, J. Doe, A. Smith, and R. Taylor. [Online]. Accessible:

<https://arxiv.org/pdf/2408.00197>